

SALESFORCE FASTMCP CONNECTOR

Security Assessment Summary

Assessment Date: June 16, 2026 | Status: APPROVED FOR DEPLOYMENT

KEY FINDINGS

Category	Score	Status
Authentication & Authorization	9/10	EXCELLENT
Injection Attack Prevention	9/10	EXCELLENT
Credential Management	9/10	EXCELLENT
Input Validation	8/10	GOOD
Error Handling & Logging	9/10	EXCELLENT
Dependency Management	6/10	FAIR
Sensitive Data Protection	9/10	EXCELLENT
Code Security Practices	8/10	GOOD
OVERALL SCORE	8.4/10	STRONG

CRITICAL FINDINGS

NO CRITICAL VULNERABILITIES FOUND

- No hardcoded secrets
- No SOQL injection vulnerabilities
- No credential leakage in logs/errors
- No unsafe subprocess execution
- No eval/exec usage
- Proper TLS/SSL configuration

VULNERABILITY ASSESSMENT

SOQL INJECTION PREVENTION: MITIGATED

All user inputs properly escaped via `_escape_soql()`

Three injection points identified and fixed:

Partner name in `get_opportunities_by_partner()`

Stage name in `get_opportunities_by_partner()`

Report name in `get_report_data()`

Test coverage: PASS (`test_soql.py`)

AUTHENTICATION: EXCELLENT

Three-tier authentication hierarchy

Primary: SF CLI with secure OS storage + auto-refresh

Fallback: Browser cookie with environment variables

Future: Direct OAuth (planned)

Credentials validated before use

No hardcoded secrets found

CREDENTIAL PROTECTION: EXCELLENT

Tokens stored in memory only (not persisted)

No tokens in logs or error messages

TLS encryption in transit

SF CLI delegates to OS secure storage

Session lifetime caching

DEPENDENCY VULNERABILITIES: FAIR

25 CVEs found in transitive dependencies (NOT in direct dependencies)

Most are in optional/indirect packages:

`urllib3` (HTTP library) - DoS/header injection risks

`starlette` (web framework) - header/method confusion risks

`torch/pytorch-lightning` (ML) - if used for LLM

`pypdf/python-multipart` (parsing) - DoS risks

Direct dependencies are clean

RECOMMENDATION: Update `urllib3` to 2.6.3+

COMPLIANCE MAPPING

Standard	Status	Details
OWASP Top 10	STRONG	Injection (A03), Auth (A07) mitigated
PCI DSS	COMPLIANT	TLS, secure development
SOC2 Type II	SUPPORTED	Auth, audit logging implemented
GDPR	COMPLIANT	Right to audit, data protection

DEPLOYMENT APPROVAL

Status: **APPROVED FOR CORPORATE DEPLOYMENT**

Prerequisites:

- Read SECURITY_BRIEF.md
- Review auth_provider.py implementation
- Apply dependency updates (Priority 1)
- Enable LOG_LEVEL=INFO for audit logging
- Document approved user list

Final Risk Rating: LOW

- Technical controls are strong
- Remaining risks are organizational (monitoring, user training)
- No show-stoppers for deployment

IMMEDIATE ACTION ITEMS (Priority 1)

1	Update urllib3	Add urllib3>=2.6.3 to constraints
2	Create lock file	Add requirements-lock.txt
3	Enable Dependabot	Automate updates on GitHub
4	Enhance audit logs	Extract username from session